

1.5 セキュリティとガバナンス

1.5.2 ガバナンスと統制

1.5.2 ガバナンスと統制

学習目標とアウトライン

学習目標

- さくらのクラウドで提供されるガバナンスと統制に用いる各種機能の特性を理解し、要件に応じたシステム統制の設計と最適化ができる

【キーワード】

サービスポリシー
セキュリティコントロール

アウトライン

- **サービスポリシー**
 - コンプライアンス違反防止
 - サービスポリシー機能
 - アクセス制御の検討
- **セキュリティコントロール**
 - セキュリティ監視と脅威検知
 - セキュリティコントロール機能
 - セキュリティコントロール運用指針

1.5.2 ガバナンスと統制

サービスポリシー

コンプライアンス違反防止

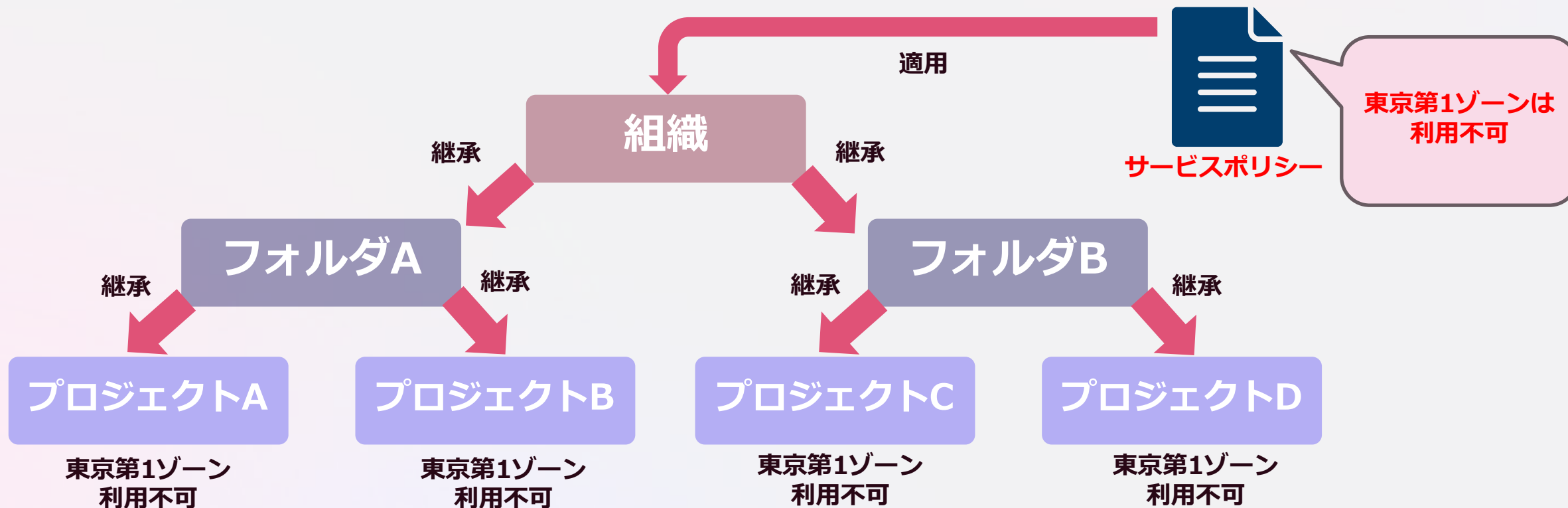
検討にあたっての考慮事項

- **クラウド利用においては、利用者の誤操作やルールの理解不足により、意図せずコンプライアンス違反が発生するリスクが存在する**
 - 操作対象の取り違いによる重要リソースの設定変更
 - 組織で許可されていないサービスや機能の利用
- **管理者が事前の操作制限を適用することで、コンプライアンス違反を未然に防止する**
 - 組織の標準的なルールテンプレートを適用し、不適切な操作をブロックする

コンプライアンス違反防止

さくらのクラウドのサービスポリシー機能について

- ・ 組織単位でリソース作成や操作を制御することができる
- ・ 誤操作やコンプライアンス違反を防ぎ、組織全体で統一したガバナンスを確立できる



サービスポリシー機能

サービスポリシー機能の設定について

①ゾーン制限 (cloud-restrict-zone)

利用できる「場所（ゾーン）」を制限する

設定例：「石狩第1ゾーン (is1a) だけ許可し、他ゾーンは使えないようにする」

②サービス制限 (cloud-restrict-service)

利用できる「機能（サービス）」を制限する

設定例：「サーバ作成 (IaaS) は許可するが、KMSや専用サーバは禁止する」

※クラウドマニュアルにて、ルールの一覧と詳細を確認することができる

サービスポリシー機能

サービスポリシー機能の設定について

③会員認証制限(`cloud-restrict-member-authentication`)

会員IDでの認証を制限する

設定例: 「さくらのクラウドにおいて会員認証を禁止し、会員IDでの利用を制限する」

④APIキー作成禁止(`iam-disable-api-key-creation`)

APIキーの新規作成を禁止する

設定例: 「APIキーの新規作成をすべて禁止し、既存キーのみ利用可能にする」

※クラウドマニュアルにて、ルールの一覧と詳細を確認することができる

アクセス制御の検討

検討にあたっての考慮事項

- ・ サービスポリシーの制限は、IAMポリシーおよびIDポリシーよりも優先して適用される
- ・ IAMポリシーおよびIDポリシーとサービスポリシーは、どちらか一方だけを使うものではなく、両方の特性を理解し、適切に組み合わせる

	IAMポリシー、IDポリシー	サービスポリシー
概要	誰が何をできるか（権限付与）	何を禁止／制限するか（操作制御）
用途	主に人（ユーザ）の権限管理に関わる	主にリソース操作の制御とガバナンスに関わる
対象	ユーザーやグループに対して付与される	リソース階層（組織）に対して継承して適用される

1.5.2 ガバナンスと統制

セキュリティコントロール

セキュリティ監視と脅威検知

検討にあたっての考慮事項

- クラウド環境では、リソースの設定ミスや意図しない構成変更が、セキュリティリスクの発生要因となる可能性がある
- アクセス制御やログ取得といった対策に加え、運用中のリソースの状態を継続的に監視し、潜在的なリスクを早期に発見・対応する仕組みが重要である
 - リソース構成の不備（例：暗号化の未設定、公開範囲の過剰な設定など）は、インシデントの原因となり得る
 - 誤った設定や予期しない変更を検出することで、被害の未然防止や対応の迅速化が可能になる
 - 監視と検知を自動化することで、人的リソースの負荷を抑えつつ、セキュリティレベルの維持・向上を図ることができる

セキュリティ監視と脅威検知

さくらのクラウドのセキュリティコントロール機能について

- クラウド環境の問題を早期に発見して対応を支援するイベントログの拡張機能であり、さくらのクラウド上のリソース設定や挙動を継続的に監視できる
 - 発見的統制
 - クラウド環境におけるリソースや設定を継続的に監視し、不正な状態や望ましくない構成を検知して通知する
 - 脅威検知
 - 不審なアクセスや挙動、潜在的な攻撃の兆候を自動的に検知し、被害が拡大する前に対応を促す

セキュリティコントロール機能

- セキュリティコントロールは、コントロールパネルのホーム画面にある「イベントログ」 > 「セキュリティコントロール」から確認することができる

さくらのクラウド ホーム

② マニュアル・サポート情報 ① お知らせ ⚠ 障害

ホーム
プロジェクト
ユーザー
2要素認証
IAMポリシー
公開鍵
イベントログ
ホストメンテナンス

さくらのクラウド
契約リソース
最適化サジェスト
利用料金管理

< イベントログ

セキュリティコントロール

リソース状態を継続監視し、セキュリティ事象を検出します。詳細は[セキュリティコントロールのマニュアル](#)をご覧ください。

ダッシュボード 対応チケット 評価結果 評価ルール 自動アクション

ダッシュボード

重大度別の評価結果

評価ルールに基づき検出された結果です。

↑ 致命的	↑ 高	→ 中	↓ 低
0	4	2	0

[すべての評価結果を見る >](#)

未完了の対応チケット

評価結果がルール違反だった場合、対応チケットが発生します。

⌚ 未対応	⌚ 対応中
12	0

[すべての対応チケットを見る >](#)

ダッシュボードは、検知された評価結果や対応状況をひと目で把握できる

セキュリティコントロール機能

- セキュリティコントロールで検出されたイベントに対して、通知やワークフローなどの自動アクションを設定できる

さくらのクラウド ホーム

イベントログ

セキュリティコントロール

リソース状態を継続監視し、セキュリティ事象を検出します。詳細は[セキュリティコントロールのマニュアル](#)をご覧ください。

ダッシュボード 対応チケット 評価結果 評価ルール 自動アクション

自動アクション

1件（自動アクション上限数： 5件）

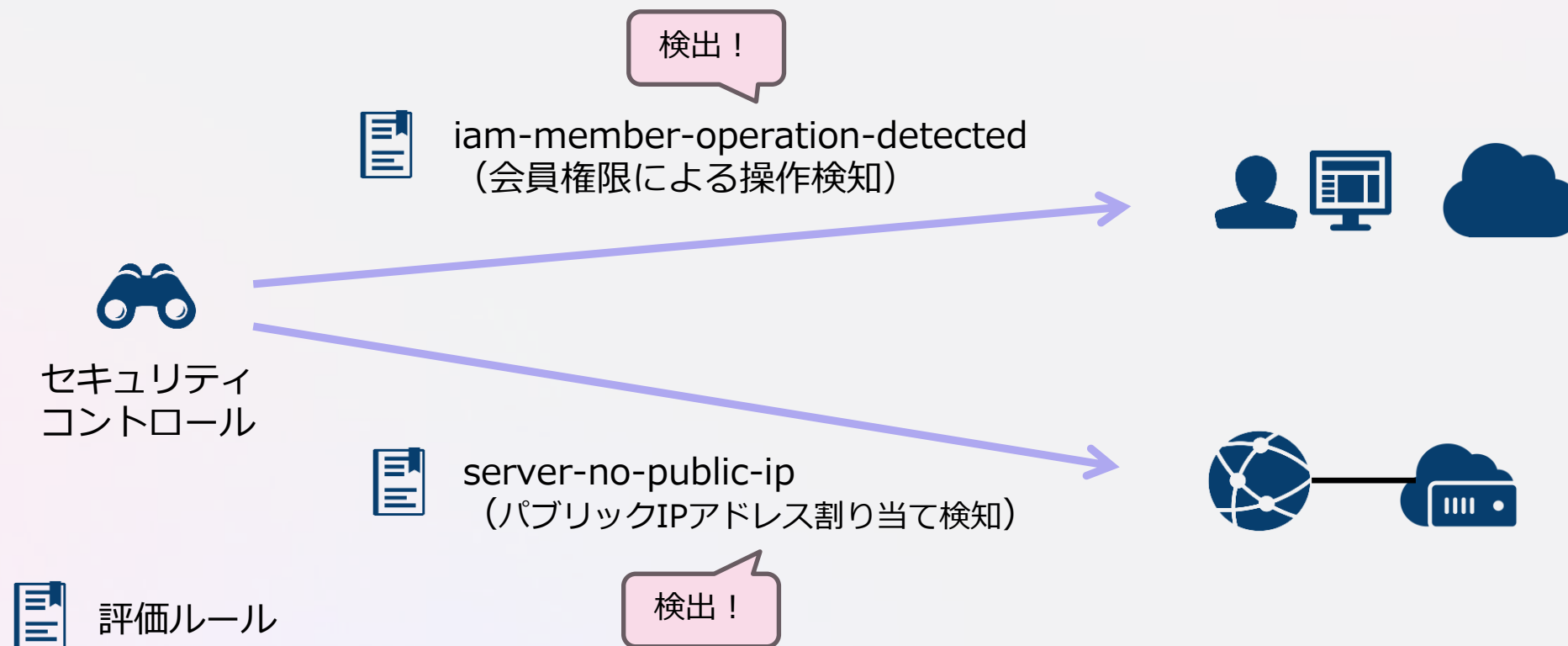
☐	アクション名	有効状態	アクション	作成日時
☐	プロジェクト用自動アクション	有効	シンプル通知	2025-12-02 11:08

- シンプル通知との連携
検出された重大度やルールに応じて、メールなどで自動通知を送信できる
- ワークフローの実行
特定の検出条件をトリガーとして、ワークフローを自動的に起動できる

セキュリティコントロール運用指針

評価ルールについて

- 各ルールに基づいて、リソースが適切に設定されているか評価される



セキュリティコントロール運用指針

評価結果と対応指針について

- セキュリティコントロールの検出結果は重大度に応じて「低・中・高／致命的」に分類され、それぞれに推奨される対応方針が定められている
- 影響が小さい項目は必要に応じて対応し、リスクが高い項目ほど、計画的または迅速な対応が求められる

重大度	説明	推奨対応
低	侵害に直接つながらない。不要なら抑止設定可	必要に応じて対応
中	悪用されればアクセス権奪取などに至る可能性あり	チケット管理し、定期的に対応検討
高 / 致命的	任意コード実行やデータ引き出しの恐れあり	可及的速やかに対応、臨時メンテ実施

セキュリティコントロール運用指針

評価結果と対応指針について

【Tips】

評価結果の取り扱いについて

評価結果はあくまで「リスクの可能性」を示すものであり、最終的な対応判断は利用者自身で行う必要があります

【本スライドについてのご案内】

本スライドは、さくらインターネット株式会社により
[CC BY-SA 4.0ライセンス](#)で提供されています。
ライセンスの条件に従う限り、自由に再利用いただけますので、
ぜひご活用ください。

※ 本スライドに、スライドのタイトル・著作権表示・無保証を参照する表示はありません。

※ 「制作協力：株式会社 zero to one」との表記につきましては、クレジットとして表示していただく必要はございません。（表示していただくことも問題ございません。）



教材制作・提供：さくらインターネット株式会社
制作協力：株式会社 zero to one

【クレジット表示について】

スライドを改変せずに再利用する場合

1. 本スライドの各ページには、再利用する場合に必要な次のクレジットが予め表示されています。

This slide is licensed under [CC BY-SA 4.0](https://creativecommons.org/licenses/by-sa/4.0/) by SAKURA internet Inc.

※ 本スライドの全部をそのままお使いになる場合（本スライドのPDFファイルをそのまま再配布される場合等）や、本スライドの一部の再利用であってもクレジット表示のなされているページをそのままお使いになる場合には、重ねて同じ表示をしていただく必要はありません。

2. 印刷して再利用する場合や画像形式に変換して再利用する場合など、リンクを貼ることができない場合には、ライセンス内容が記載された次のURLをご掲載いただくか、本ページも併せてご印刷・ご掲載ください。

<https://creativecommons.org/licenses/by-sa/4.0/deed.ja>

3. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本スライドは、さくらインターネット株式会社により[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。

【クレジット表示について】

スライドを改変の上で再利用する場合

1. 改変の上で再利用される場合、次の表示例をご参考にしてください。

This [slide or document] is adapted from the slide by SAKURA internet Inc.
The slide is licensed under [CC BY-SA 4.0](#).
This [slide or document] is licensed under [CC BY-SA 4.0](#) by [Your name here].

2. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本[スライド・資料等]は、さくらインターネット株式会社制作のスライドを改変の上利用しています。
同スライドは、[CC BY-SA 4.0ライセンス](#)で提供されています。
本[スライド・資料等]は、[スライド・資料等の制作者の氏名・名称]により[CC BY-SA 4.0ライセンス](#)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。